



Future Interns

Cyber Security Task 1 (2026)

Vulnerability Assessment Report

example.com - Security Analysis

Prepared by Ebasa Getu

Report Metadata

Target	https://example.com
Date	June 2026
Methodology	Read-Only Passive Analysis
Scope	Public pages, headers, SSL/TLS, DNS
Analyst	Ebasa Getu

Executive Summary

A read-only vulnerability assessment was performed on example.com. The assessment focused on security header configuration, SSL/TLS implementation, and information disclosure risks. Of the eight security headers recommended by industry standards (OWASP, Mozilla Observatory), seven were found to be missing or improperly configured.

The most critical finding is the absence of a Content-Security-Policy header, which leaves the site vulnerable to cross-site scripting attacks. All findings are remediable with straightforward server configuration changes.

Risk Summary

#	Finding	Severity	Impact
1	Missing Content-Security-Policy (CSP)	High	Without CSP, if an attacker finds an XSS vulnerability anywhere on the...
2	Missing X-Frame-Options Header	Medium	An attacker can embed the website in an invisible iframe on a malicious...
3	Missing Strict-Transport-Security (HSTS)	Medium	Users can connect over HTTP, exposing all transmitted data to interception...
4	Missing X-Content-Type-Options Header	Medium	Attackers can potentially bypass Content-Type checks by having the browser...
5	No HTTP-to-HTTPS Redirect	Medium	An attacker on public Wi-Fi can intercept HTTP traffic, inject malicious...
6	Server Information Disclosure	Low	Disclosed server information helps attackers identify potential vulnerabilities...
7	Missing Referrer-Policy Header	Low	Sensitive data in URLs may leak to third-party sites. Privacy-conscious users...
8	Missing Permissions-Policy Header	Low	Third-party scripts or iframes could potentially access sensitive device...

Finding 1: Missing Content-Security-Policy (CSP)

Severity	High
Endpoint	https://example.com

Description

The Content-Security-Policy header is not set. CSP is a critical security layer that helps detect and mitigate cross-site scripting and data injection attacks by controlling which resources the browser is allowed to load.

Business Impact

Without CSP, if an attacker finds an XSS vulnerability anywhere on the site, they can inject arbitrary scripts, steal cookies, redirect users to malicious sites, or deface the page.

Remediation

1. Add Content-Security-Policy: default-src 'self' header
2. Start with report-only mode to monitor violations before enforcing
3. Include specific directives: script-src, style-src, img-src
4. Avoid unsafe-inline and unsafe-eval in production policies

Finding 2: Missing X-Frame-Options Header

Severity	Medium
Endpoint	https://example.com

Description

The X-Frame-Options header is not configured. This header prevents the page from being embedded in iframes on other websites, protecting against clickjacking attacks.

Business Impact

An attacker can embed the website in an invisible iframe on a malicious page, tricking users into performing actions they did not intend.

Remediation

1. Add X-Frame-Options: DENY to prevent all framing
2. Use SAMEORIGIN if framing by the same origin is needed
3. Also add frame-ancestors directive in CSP for modern browsers

Finding 3: Missing Strict-Transport-Security (HSTS)

Severity	Medium
Endpoint	https://example.com

Description

The HSTS header is not present. HSTS instructs browsers to always connect via HTTPS, preventing SSL-stripping attacks.

Business Impact

Users can connect over HTTP, exposing all transmitted data to interception by attackers on the same network.

Remediation

1. Add Strict-Transport-Security: max-age=31536000; includeSubDomains
2. Start with a lower max-age then increase gradually
3. Submit domain to browser HSTS preload lists

Finding 4: Missing X-Content-Type-Options Header

Severity	Medium
Endpoint	https://example.com

Description

The X-Content-Type-Options header is not configured. Without it, browsers may perform MIME-type sniffing.

Business Impact

Attackers can potentially bypass Content-Type checks by having the browser interpret files differently than declared.

Remediation

1. Add X-Content-Type-Options: nosniff to all responses
2. Ensure all responses include accurate Content-Type headers
3. Validate uploaded file MIME types server-side

Finding 5: No HTTP-to-HTTPS Redirect

Severity	Medium
Endpoint	http://example.com

Description

The HTTP version responds with 200 OK instead of redirecting to HTTPS, meaning unencrypted connections are accepted.

Business Impact

An attacker on public Wi-Fi can intercept HTTP traffic, inject malicious content, or steal credentials before any HTTPS upgrade.

Remediation

1. Configure 301 redirect from HTTP to HTTPS for all traffic
2. Implement HSTS to ensure browsers remember HTTPS
3. Add domain to HSTS preload lists

Finding 6: Server Information Disclosure

Severity	Low
Endpoint	https://example.com

Description

The Server header reveals the server technology (cloudflare), aiding attacker reconnaissance.

Business Impact

Disclosed server information helps attackers identify potential vulnerabilities specific to the technology stack.

Remediation

1. Strip or minimize Server header information
2. Use generic values or remove the header entirely
3. Review CDN header disclosure settings

Finding 7: Missing Referrer-Policy Header

Severity	Low
Endpoint	https://example.com

Description

The Referrer-Policy header is not configured. The browser sends the full URL as the Referer header when users navigate to external sites.

Business Impact

Sensitive data in URLs may leak to third-party sites. Privacy-conscious users may be tracked across sessions.

Remediation

1. Add Referrer-Policy: strict-origin-when-cross-origin
2. Use no-referrer for highly sensitive pages
3. Test external links to verify referrer behavior

Finding 8: Missing Permissions-Policy Header

Severity	Low
Endpoint	https://example.com

Description

The Permissions-Policy header is not configured, leaving browser features (camera, microphone, geolocation) unrestricted.

Business Impact

Third-party scripts or iframes could potentially access sensitive device features without explicit permission.

Remediation

1. Add Permissions-Policy: geolocation=(), camera=(), microphone=()
2. Audit which features are actually needed by the application
3. Review third-party scripts for feature requirements

Methodology and Tools

Analysis Approach

This assessment was conducted using a strictly read-only, passive approach. No active exploitation, brute force, or denial-of-service testing was performed. The methodology follows the OWASP Web Security Testing Guide guidelines for information gathering and configuration review.

Tools Used

Tool	Purpose
curl	HTTP/S request inspection
openssl	SSL/TLS analysis
host/dig	DNS resolution
Browser DevTools	Response header review

Scope

In Scope: Public-facing pages and endpoints at <https://example.com> and <http://example.com>. Passive security header review, SSL/TLS configuration analysis, DNS record inspection, and directory enumeration.

Out of Scope: No active exploitation, no authentication bypass attempts, no brute force testing, no denial-of-service testing, no injection attempts.